

Pautas para Gerentes

Seguridad de la Información



Diseño del Sistema de Resiliencia y Ajuste con los Estándares

Este sistema de resiliencia lo diseñó la Corporación Risk and Strategic Management (RSM), una compañía especialista en el diseño y la implementación de estrategias complejas de resiliencia que protegen a las personas, las instalaciones, los bienes, la información, las operaciones y la reputación organizacional. Este sistema se encuentra en conformidad con las siguientes normas de la ISO y la BSI para garantizar que refleja las normas y prácticas profesionales de las Organizaciones de Alta Confiabilidad: ISO 31000: Gestión del Riesgo; ISO 22317: Análisis de impacto comercial; ISO 22301: Gestión de la continuidad de negocio; ISO 22320: Gestión de Emergencias; ISO 34001: Seguridad y resiliencia; ISO 22316: Resiliencia organizacional y BSI 17091: Gestión de crisis.

¿Por qué la seguridad de la información es necesaria?

Una seguridad de la información eficaz garantiza que ningún dato se pierda, robe ni quede desprotegido independientemente de su confidencialidad. Cualquier información que pueda causar daño o vergüenza a las personas, la organización o las partes interesadas externas por parte de delincuentes, gobiernos hostiles, medios de comunicación, militantes o terroristas debe considerarse sensible y protegerse adecuadamente. Entre los ejemplos específicos de información confidencial se incluyen los siguientes:

- Información contractual y financiera
- Planes e informes operativos
- Estrategias organizacionales
- Información de las partes interesadas externas
- Propuestas comerciales
- Visitas y actividades VIP
- Propiedad intelectual
- Registros y programas de viaje
- Datos personales del personal y registros de familiares más cercanos
- Informes promocionales y disciplinarios
- Políticas o informes de crisis e incidentes
- Documentos de seguros
- Paquetes de compensación
- Reuniones y eventos con clientes
- Investigaciones
- Planes y políticas de seguridad

Los riesgos de una seguridad de la información deficiente incluyen:

- Robo, atracos, asaltos y entradas
- Agresiones que resulten en lesiones o la muerte
- Secuestro y toma de rehenes
- Ataques armados
- Atención negativa de los medios
- Pérdida de ventaja competitiva y negocios
- Vergüenza individual u organizacional
- Riesgos legales y reputacionales
- Daños a la moral de los empleados
- Perjuicio a las partes interesadas externas

Responsabilidades de la gerencia

Los gerentes son responsables de garantizar que todo el personal y los subcontratistas lleven a cabo los protocolos de seguridad de la información física y de procedimientos para evitar el robo o la pérdida de datos. La falta de implementación de estas medidas puede resultar en una brecha de la seguridad. La eficacia de la seguridad de la información se basa en:

- Limitar el acceso a los datos mediante el uso de cifrado en capas y protocolos de seguridad
- Implementar y hacer cumplir una "política clara"
- Proteger la información en activos de almacenamiento de datos físicos o la información impresa
- Reducir las vulnerabilidades que podrían permitir la pérdida o el robo de datos
- Reportar las violaciones de seguridad de inmediato
- Asegurarse de que el personal esté debidamente capacitado y supervisado

La seguridad de la información se basa en:

La confidencialidad	La integridad	La disponibilidad
Prevenir la divulgación de información a personas o sistemas no autorizados.	Prevenir la modificación de los sistemas o el almacenamiento de datos sin la debida autorización.	Mantener los datos y sistemas disponibles para su uso por personas autorizadas.

La confidencialidad

Los datos que se encuentran en servidores, bases de datos, carpetas con información impresa o están visibles en los escritorios o áreas abiertas de los miembros del personal no deben ser accedidos por personas que no tengan la autorización, identificación y/o protección adecuadas. La confidencialidad incluye:

- **La habilitación:** es una base de protección basada en niveles de defensa. Esto se refiere a la cantidad de datos a los que se le permite acceder y/o cuándo puede acceder a ellos. Los individuos/sistemas a los que se les otorga una habilitación 'más alta' pueden acceder a más datos.
- **Identificación:** es una base para que pueda demostrar que tiene la habilitación correcta. Gira en torno a *algo que usted sabe*, *algo que usted tiene* o *algo que usted es*. Ejemplos de cada uno de estos son: *algo que usted sabe*: "¿Cuál es el apellido de soltera de su madre?", Un número de identificación PIN o una contraseña; *algo que usted tiene*: una tarjeta magnética, licencia de conducir; *algo que usted es*: datos biométricos (por ejemplo, escaneo de retina, huellas dactilares, impresiones de voz, etc.)
- **Protección:** la protección consta de dos partes: la *autorización* y la *identificación*, [1] *La autorización* se ve más comúnmente como un nombre de usuario asignado o una tarjeta magnética, y [2] la *identificación* es una contraseña o palabra clave asignada a esa identificación.

Una "brecha" ocurre cuando personas no autorizadas acceden a los datos. El gerente debe informar una brecha de inmediato y comenzar a buscar la ubicación donde esta ocurrió en el sistema; es decir, el *punto de entrada* donde ocurrió la brecha. Una vez que usted aplica la **habilitación**, la **identificación** y la **protección** correctamente, solo las personas autorizadas deberían tener acceso a los datos.

La integridad

La integridad se basa en prevenir que los datos sean modificados cuando se produce una brecha. La protección de datos con contraseña es un método común para aumentar la integridad. Otros métodos incluyen el registro de todos los cambios en los datos y la retención de estos registros para que el alcance y el impacto de cualquier brecha se puedan analizar y mitigar. Al igual que con cualquier tipo de seguridad, es mejor implementarla en niveles para maximizar la protección y minimizar el riesgo. Un buen enfoque sistemático para la seguridad de los sistemas de TI de su oficina es utilizar una combinación de políticas y tecnologías que incluyan la protección de datos con contraseña, con permisos de archivo limitados (adaptados al departamento/usabilidad/disponibilidad), un firewall de alta seguridad, cifrado de datos y una red de enrutamiento apropiada.

La disponibilidad

La disponibilidad comprende la disponibilidad virtual y física, es decir, el acceso a los sistemas de forma electrónica y la capacidad de los activos de almacenamiento o procesamiento de ser vulnerados. Si bien un bloqueo total de los sistemas podría ser completamente seguro, no sería accesible. La disponibilidad de datos es una idea opuesta que debe equilibrarse en consecuencia cuando se construye una red o un acceso general a la información. Esto requiere permitir cierta libertad a los usuarios, pero debe permanecer limitado según sea necesario. Los gerentes deben aplicar capas de acceso -crear estructuras de archivo específicas en un servidor de archivos o sitio de SharePoint que permita a los usuarios acceder solamente a las áreas requeridas según su función- y así restringir la información según "*la necesidad de conocimiento*". Esta estrategia también debe aplicarse a archivos de datos almacenados en papel, como los expedientes del personal, los registros contractuales y financieros, las políticas y planes de seguridad y los planes de oficina e informes confidenciales.

Los gerentes deben proteger la información considerando la aplicación de:

- **Una política de escritorio despejado:** una "política de escritorio despejado" puede limitar la disponibilidad de información a personas no autorizadas. La información confidencial puede guardarse bajo llave cuando no esté en uso, especialmente durante la noche, cuando los limpiadores pueden tener acceso sin restricciones a las instalaciones. El personal que utiliza datos confidenciales debe disponer de armarios o salas con cerradura donde se puedan proteger los datos. La política de escritorio en esta oficina contempla que:

Sí	No	Controles de seguridad de la información
		Todos los materiales sensibles se guardan en escritorios al final del día
		Se proporcione un gabinete/contenedor con cerradura exclusivamente para proteger la información
		Se proporcione una sala exclusivamente para proteger la información

- **Protección de datos:** las salas de servidores deben estar protegidas para evitar el acceso e idealmente tener un sistema de alarma instalado para alertar a los gerentes de una brecha. Las memorias USB y otros dispositivos portátiles deben guardarse bajo llave o llevarse encima del usuario.
- **Viajar con datos:** los viajeros deben considerar qué información necesitan para el viaje y si la pérdida de cualquier información puede comprometer a las personas, la oficina o la organización. El personal no debe almacenar datos confidenciales en memorias USB o discos duros externos a menos que estén autorizados para hacerlo. A menos que se tenga autorización, las memorias USB, discos duros externos o activos de TI de terceros no deben conectarse a una computadora de trabajo.

Pérdida y eliminación de datos

Los gerentes y el personal deben comprender el proceso correcto para eliminar los datos o los riesgos de robo de datos cuando el equipo o los documentos se eliminan o transfieren a otra oficina. A menudo, los activos de TI retienen datos confidenciales, incluso después de que el personal crea haber saneado el activo. Se tomarán las siguientes medidas durante la eliminación de datos o cuando se haya producido el robo de datos:

- **Robo de datos:** si se produce una pérdida o robo de datos o activos, el personal y los gerentes deben informar de inmediato el incidente y proporcionar una lista completa de la información robada o perdida para que se pueda realizar una evaluación de riesgos en cuanto a las posibles implicaciones de la pérdida. Se debe notificar a todas las partes afectadas, incluidas las partes interesadas internas y externas afectadas. Es posible que también sea necesario informar a la policía y/o agencias gubernamentales. Se aplican las mismas consideraciones si se cree que los datos se han visto comprometidos. Los robos de datos deben informarse inmediatamente a la sede central.
- **Borrado de datos:** el Departamento de Tecnología de la Información es responsable de desechar todos los dispositivos de red, discos duros, memorias USB y computadoras para garantizar que el contenido de estos se borre por completo.
- **Desecho de identidades:** las identidades y las computadoras pueden desecharse si se ven comprometidas. Estas identidades desechables evitan el hostigamiento de los acosadores, dándole al usuario la opción de elegir quién puede conocer su nueva identificación de correo electrónico.

- **Desecho de datos duros:** los archivos de datos duros, el papel y los documentos deben destruirse de manera que se proteja la integridad de la información. Esto puede ser mediante el uso de una trituradora o, en ausencia de una, quemando los documentos. En algunas áreas, se puede contratar a empresas profesionales para eliminar los datos de forma segura. Se debe examinar a dichas empresas antes de contratarlas.